CTI Write-up of LAPSUS$

This is a quick investigation into the hacking group known as LAPSUS$ (DEV-0537) including a brief history, dive into the structure of the organization in regards to the Diamond model, as well as how the group might operate while attacking a target. This is purely for education and portfolio purposes and a though-process on how to better protect our organizations from similar threats.

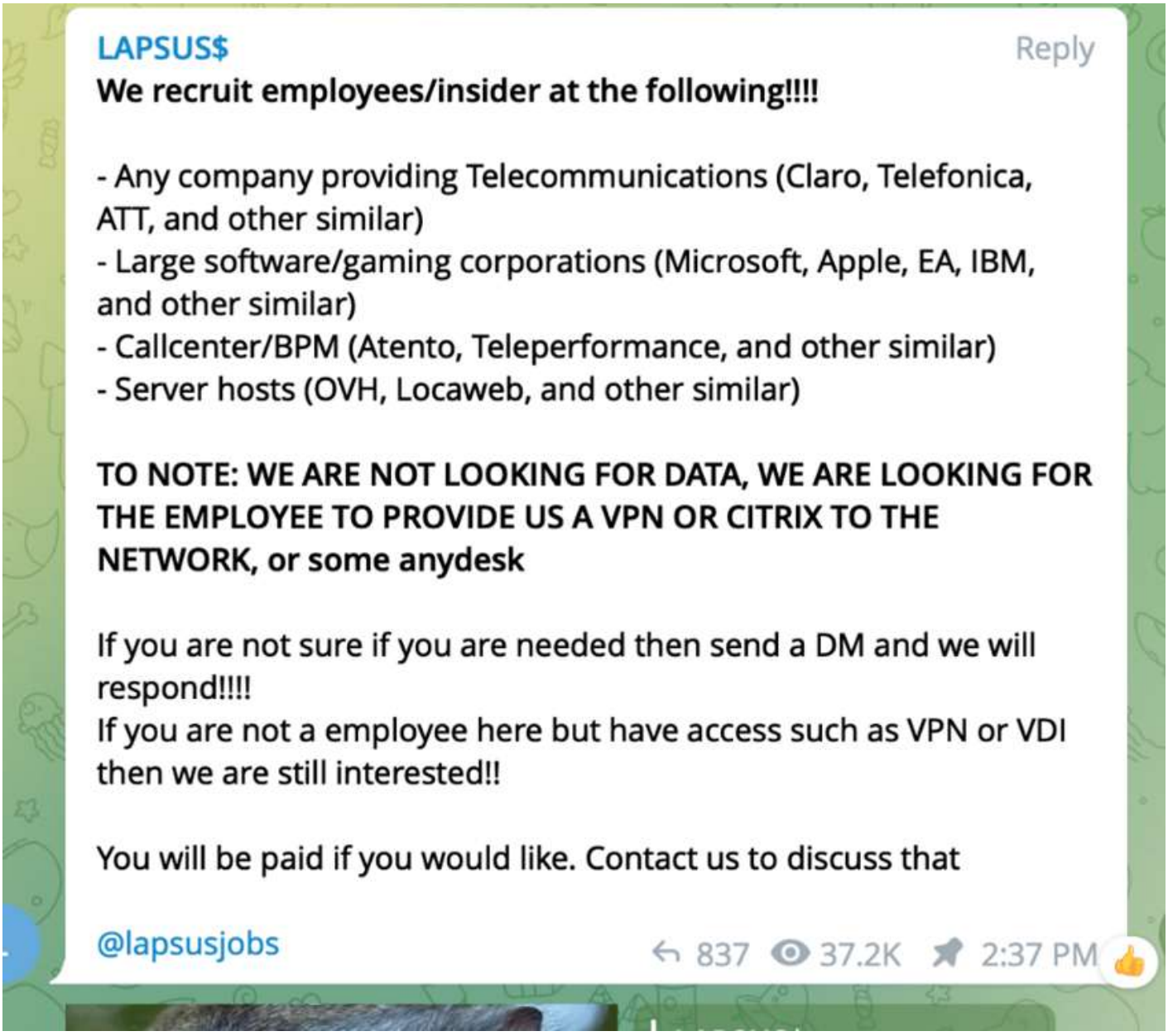
Executive Summary

Late 2021 through 2022 a hacker group known as LAPSUS$ managed to steal data from major organizations spanning tech, telecom, retail and healthcare such as Microsoft, NVIDIA, and the Brazilian Ministry of Health. Through the use of social engineering and compromised employees (offered payment for their login credentials), the group was able to infiltrate and escalate causing nearly $10 million dollars in direct damages. Differing from other ransomware groups, the group often used extortion tactics and public "shaming" of the companies in order to force compliance. Security experts recommend utilizing strong MFA beyond SMS messages and IAM techniques to help mitigate possible stolen credentials.

History

It is speculated that the group was formed sometime in mid-late 2021 with their first major attacks being carried out in Dec 2021 and into early 2022. Originally targeting organizations in the UK and South America, by 2022 the group expanded their reach globally and on an individual level stealing crypto wallets and sensitive data. Most known for their extortion techniques and social engineering for intel gathering, what really sets the group apart from their peers is that unlike most ransomware groups LAPSUS$ didn't encrypt or otherwise lock the stolen data from its owners. Rather than encrypting and holding the data hostage (the Availability of the CIA triad), LAPSUS$ targeted the confidentiality; threatening to release the sensitive data to the public if their demands weren't met.

While their main motives publicly stated to be monetary via extortion payments and theft of crypto wallets, it is speculated that the group also carried out attacks for notoriety and general disruption. Evidence of this can be noted in that the release of stolen data before any payments or negotiations have been made. *(1)* Furthering the idea that LAPSUS$ was after notoriety was their openness around their processes. It was almost unheard of in the cyber community but the group would announce their interest in buying credentials from potential prey as a part of the reconnaissance and posting their victories on their *public* telegram channel. *(2)*



(2)

Their most notorious attacks targeted major corporations such as Microsoft, Nvidia, Samsung, and the Brazilian Ministry of Health. One of the more well documented attacks occurred in Jan 2022 targeting Okta, a company specializing in Identity and Access Management software. *(3)* Attackers gained access to a support engineer's laptop for 5 days and were able to escalate their privileges to admin over the next two months. While the CSO of Okta, David Bradbury, claimed that the group was only able to access base level permissions, the support engineer accounts did have access to full user lists and the ability to reset passwords and MFA factors - which led to the compromise of user credentials.

Diamond Model

Focusing on the diamond model's 4 points of adversaries, infrastructure, capabilities, targets and the relationships between these points.

Targets

Ministry of Health of Brazil - COVID database and confidential info and defacement

NVIDIA - employee credentials and propriety data (firmware, schematics, drivers)

Samsung - DRM modules, authentication mechanisms, bootloaders

Okta - customer data including passwords and MFA data

Microsoft - source code for Bing, Bing Maps, and Cortana

Ubisoft - service disruption

LG - hashes of user and service accounts

T-Mobile - Slack and Bitbucket repos

And a variety of other less known vendors and organizations *(4)*

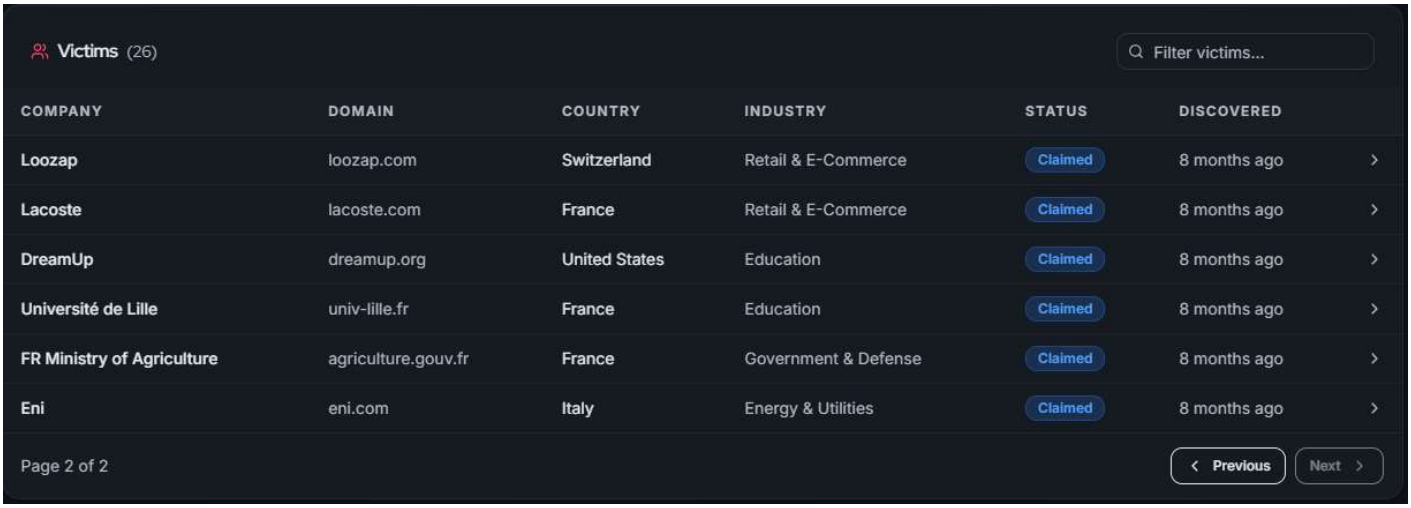


Victims (26)

Filter victims...

COMPANY	DOMAIN	COUNTRY	INDUSTRY	STATUS	DISCOVERED
dinq.me	dinq.me	—	—	Claimed	8 days ago
VirtaHealth	—	United States	Healthcare	Claimed	14 days ago
AI company	—	—	Technology	Claimed	14 days ago
AYA BANK	ayabank.com	Myanmar	Financial Services	Claimed	4 months ago
INGKA GROUP	ingka.com	Sweden	Retail & E-Commerce	Claimed	4 months ago
GitHub	github.com	United States	Technology	Data Leaked	4 months ago
VODAFONE	—	Germany	Technology	Claimed	5 months ago
AXCERA TRADING	—	United States	Professional Services	Claimed	6 months ago
Mapfre	mapfre.com	Spain	Financial Services	Data Leaked	5 months ago
CHECKMARX	checkmarx.com	United States	Technology	Claimed	6 months ago
Axcera	axcera.io	United Arab Emirates	Technology	Claimed	7 months ago
UNIV LILLE	—	France	Education	Claimed	7 months ago
ASTRAZENECA CORP	—	United Kingdom	Healthcare	Claimed	7 months ago
MERCOR	mercor.com	United States	Professional Services	Data Leaked	5 months ago
FR MINISTRY AGRI	—	France	Government & Defense	Claimed	8 months ago
ADIDAS EXTRANET	—	—	Retail & E-Commerce	Claimed	8 months ago
Groupe Eiffage	eiffage.com	France	Other	Claimed	8 months ago
OSAC	osac.aero	France	Manufacturing	Claimed	8 months ago
Tulip	salesfloor.com	Canada	Technology	Claimed	8 months ago
Adidas	adidas.de	Germany	Retail & E-Commerce	Claimed	8 months ago

Page 1 of 2 Previous Next



Victims (26)

Filter victims...

COMPANY	DOMAIN	COUNTRY	INDUSTRY	STATUS	DISCOVERED
Loozap	loozap.com	Switzerland	Retail & E-Commerce	Claimed	8 months ago
Lacoste	lacoste.com	France	Retail & E-Commerce	Claimed	8 months ago
DreamUp	dreamup.org	United States	Education	Claimed	8 months ago
Université de Lille	univ-lille.fr	France	Education	Claimed	8 months ago
FR Ministry of Agriculture	agriculture.gouv.fr	France	Government & Defense	Claimed	8 months ago
Eni	eni.com	Italy	Energy & Utilities	Claimed	8 months ago

Page 2 of 2 Previous Next

(5)

Adversaries

LAPSUS$ AKA DEV-0537, Strawberry Tempest, Slippy Spider *(6) (7)*

Possible ties to other cybercriminal groups: Yanluowang, Oktapus/Roasted Oktapus, Karakurt, Nwgen Team, #NotLapsus *([8])(https://www.cisa.gov/sites/default/files/2023-08/CSRB_Lapsus%24_508c.pdf))*

Leader: "White"/"Oklaqq" Arion Kurtaj (Oxford, England) and unknown Brazilian member *(9)*

Infrastructure

Communication mostly via public and private Telegram

Staging via cloud infrastructure aka Virtual Service Providers

Often reused similar or even same attack patterns and VSPs leading to the tracking of the group

Capabilities

More notable tactics used

- T1586 .002 Purchasing employee credentials in an attempt to gain a foothold in the organizations
- T1204 Recruiting employees and contractors to provide credentials and approve MFA promts or install remote software on workstations
- T1087 .002 Use of the AD Explorer tool to find users on victim's networks
- T1451 SIM swapping to bypass MFA SMS authentication on victims' phones
- T1199 Falsly impersonating IAM providers such as Azure AD and Okta to get credentials
- Using company communication channels such as Slack or Teams to better understand the incident response playbook, and use that info to alter their response *(2)*

Full list *(6)*

Recommendations

- Greater MFA practices, such as requiring MFA for all users and all locations that are internet-accesible
- Stronger MFA than SMS which can be bypassed with a SIM card swap
- Educate employees on the importance of personal credentials, and how a leak can snowball into greater access within the company
- Encrypted communication channels and ensuring proper principle of least privilege access to prevent unwanted disclosures
- Policies to block user creation or security enrollment without proper oversight (preventing a stolen credential from locking out the intended user)

References

(1) https://reliaquest.com/blog/team-a-vs-team-b-what-is-motivating-lapsus

(2) https://www.microsoft.com/en-us/security/blog/2022/03/22/dev-0537-criminal-actor-targeting-organizations-for-data-exfiltration-and-destruction/

(3) https://keepnetlabs.com/blog/make-sure-you-have-a-variety-of-security-procedures-in-place

(4) https://www.picussecurity.com/resource/the-lapsus-group-a-chaotic-start-of-ransomware-free-extortion

(5) https://socradar.io/free-tools/ransomware-intelligence/groups/lapsus

(6) https://attack.mitre.org/groups/G1004/

(7) https://www.huntress.com/threat-library/threat-actors/lapsus

(8) https://www.cisa.gov/sites/default/files/2023-08/CSRB_Lapsus%24_508c.pdf

(9) https://www.dexpose.io/lapsus/